

מטרות: מערכות VPN · הגדרת VPN · IPsec · הגדרת ב-Cli · GRE · SSL VPN
בבגרות: IPsec מאבטח את חבילת TCP/IP (שכבה 3)

לפני שמתחילים – מה זו "מנהרה מוצפנת"? (למי שאין רקע)

הבעיה: כשמידע עובר באינטרנט, הוא עובר דרך נתבים רבים של חברות שונות. כל אחד בדרך יכול, עקרונית, לראות אותו. זה מסוכן למידע רגיש. VPN = "Virtual Private Network" רשת פרטית וירטואלית". הוא יוצר **מנהרה מוצפנת** דרך האינטרנט הציבורי: המידע מוצפן בצד אחד, עובר את האינטרנט כג'יבריש, ומפוענח רק בצד השני. **אנלוגיה:** במקום לשלוח גלויה שכל דוור קורא (אינטרנט רגיל), שולחים מזוודה נעולה שרק לשולח ולנמען יש מפתח אליה. (VPN) **שני שימושים:** חיבור פניסל (Site-to-Site), כמו לחבר שני משרדים, וחיבור תיבהמ דבוע. (Remote Access) **חשוב:** פרק זה מסתמך ישירות על פרק 7 (הצפנה). כל מה שנלמד שם – מפתח סימטרי, מפתח ציבורי/פרטי, גיבוב – חוזר כאן בפעולה. אם משהו לא ברור, חזרו לפרק 7.

8.1 מהו VPN ולמה הוא נחוץ

VPN (Virtual Private Network) יוצר "מנהרה" מוצפנת דרך רשת ציבורית (האינטרנט), כך שנתונים עוברים כאילו הם על קו פרטי. במקום לשכור קו תקשורת יקר בין סניפים (leased line), משתמשים באינטרנט הזול – והצפנה מספקת את הפרטיות. VPN מספק את שלוש מטרות ה-CIA לתעבורה: **סודיות** (הצפנה), **שלמות** (HMAC), **אימות** (מי הצד השני), ולעיתים anti-replay (מניעת שידור חוזר של חבילה שנלכדה).

סיפור מהחיים: בית הקפה והמנהל שעבד מרחוק

מנהל מכירות יושב בבית קפה, מתחבר ל-Wi-Fi הפתוח, ופותח את מערכת ה-CRM של החברה. בלי VPN, כל מי שיושב בבית הקפה עם Wireshark (או Evil Twin – פרק 6) רואה את הכול. עם VPN: המחשב פותח מנהרת IPsec/SSL מוצפנת אל שער החברה עוד לפני שנשלח ביט אחד של CRM. המאזין רואה רק "תעבורה מוצפנת ל-VPN gateway" – ג'יבריש. זה בדיוק מה שלמדנו בפרק 7 (AES+HMAC+DH), עכשיו ארוז כשירות רשת.

8.2 סוגי VPN

סוג	מי מתחבר למי	דוגמה
Site-to-Site	שער (נתב)/ASA לשער – מחבר שתי רשתות שלמות. שקוף למשתמשים	סניף תל אביב ↔ סניף חיפה
Remote Access	משתמש יחיד (לקוח) ↔ שער החברה	עובד מהבית ↔ המשרד (Cisco AnyConnect)

לפי מי מפעיל	
Enterprise VPN	הארגון מנהל (IPsec, SSL) – מה שנלמד כאן
Service Provider VPN	ספק התקשורת מספק – Metro Ethernet, MPLS (MPLS, GRE) (מוזכר בתכנית)

הבהרה חשובה

"VPN מסחרי" (NordVPN וכו') נועד להסתרת זהות/מיקום – שימוש שונה מ-VPN ארגוני שמחבר משתמש/סניף לרשת החברה בבטחה. בקורס מדובר ב-VPN ארגוני.

GRE 8.3 – מנהור בסיסי (בלי הצפנה!)

GRE (Generic Routing Encapsulation) הוא פרוטוקול מנהור של סיסקו שעוטף חבילה בתוך חבילת IP חדשה. יתרון: יכול לשאת multicast ו-broadcast (ולכן פרוטוקולי ניתוב כמו OSPF/EIGRP רצים דרכו) וגם תעבורה שאינה IP. חיסרון קריטי: GRE אינו מצפין כלום – הוא רק עוטף. לכן בפועל: GRE – GRE over IPsec. נותן את הגמישות (multicast, routing), IPsec, נותן את ההצפנה.

```
R2 ל-R1 בין GRE מנהרת !
R1(config)# interface tunnel 0
R1(config-if)# ip address 172.16.1.1 255.255.255.252 ! כתובת פנימית של המנהרה
R1(config-if)# tunnel source 200.1.1.1 ! ה-IP הציבורי המקומי
R1(config-if)# tunnel destination 200.2.2.2 ! ה-IP הציבורי המרוחק
R1(config-if)# tunnel mode gre ip ! ברירת מחדל
! עכשיו מנתבים דרך המנהרה
R1(config)# ip route 10.2.2.0 255.255.255.0 172.16.1.2
R1# show ip interface brief | include Tunnel
R1# show interfaces tunnel 0
```

IPsec 8.4 – לב הפרק

IPsec אינו פרוטוקול יחיד אלא מסגרת (framework) של פרוטוקולים שמאבטחת תעבורה בשכבה 3 (IP). זו התשובה בבגרות: "IPsec נועד לאבטח את חבילת הפרוטוקולים TCP/IP כיוון שהוא בשכבה 3, הוא מאבטח כל תעבורה מעליו (TCP, UDP), כל אפליקציה (בשקיפות – בניגוד ל-SSL/TLS שבשכבה גבוהה יותר).

בבגרות (שאלה 6א)

"איזה סוג תקשורת נועדה חבילת הפרוטוקולים IPSEC לאבטח?" – TCP/IP. 2. (שכבה 3). לא SSH, לא Telnet, לא UDP ספציפית.

שני פרוטוקולי ההגנה

	AH (Authentication Header)	ESP (Encapsulating Security Payload)
פרוטוקול IP	51	50
שלמות + אימות	כן (כולל הכותרת החיצונית)	כן (המטען)
סודיות (הצפנה)	לא!	כן
עובד עם NAT	לא (מגן על הכותרת)	כן (עם NAT-T)
שימוש	כמעט לא בשימוש (אין הצפנה)	הבחירה כמעט תמיד

שני מצבי פעולה

- Transport mode – מצפין רק את המטען (payload); הכותרת המקורית נשמרת. בין שני מארחים.
- Tunnel mode – מצפין את כל החבילה המקורית ועוטף בכותרת IP חדשה. בין שערם (site-to-site). הנפוץ.

ארבעת מרכיבי ה-IPsec (מה שהמנהל צריך לבחור)

תפקיד	אפשרויות
הצפנה (סודיות)	AES / DES / 3DES
שלמות (hash)	(HMAC) SHA / MD5
אימות הצדדים	PSK (מפתח משותף מראש) / (תעודות PKI) RSA – פרק 7
החלפת מפתחות	DH (Diffie-Hellman) – קבוצות 1,2,5,14...

שימו לב: כל מה שלמדנו בפרק 7 חוזר כאן - AES לסודיות, SHA-HMAC לשלמות, DH להחלפת מפתחות, RSA/PKI לאימות. IPsec הוא "פרק 7 בפעולה".

IKE 8.5 - ניהול המפתחות והמנהרה

IKE ("Internet Key Exchange") מפתחות אינטרנט משתנים" בתכנית) הוא הפרוטוקול שמקים את מנהרת ה-IPsec: מבצע DH, מאמת את הצדדים, ומסכים על הפרמטרים. פועל בשני שלבים:

IKE Phase 1 - בונים ערוץ ניהול מאובטח (ISAKMP SA)

הצדדים מסכימים על מדיניות (הצפנה/DH/hash/אימות), מבצעים DH, ומאמתים זה את זה (PSK או תעודות). התוצאה: ערוץ מוצפן דו-כיווני אחד שבו ינוהל שלב 2. מצבים: 6 Main mode (הודעות, בטוח) או 3 Aggressive mode, מהיר).

IKE Phase 2 - בונים את מנהרת הנתונים (IPsec SA)

בתוך הערוץ המאובטח משלב 1, מסכימים על ה- transform set (ESP-AES-SHA) ומקימים שני SA חד-כיווניים (אחד לכל כיוון) שדרכם תעבור התעבורה בפועל. מצב: Quick mode.

SA (Security Association) - "הסכם" חד-כיווני שמגדיר איך לאבטח זרם תעבורה מסוים, עם מזהה SPI. Phase 2 מייצר PFS (Perfect Forward Secrecy) אם מפעילים DH מחדש - כך שדליפת מפתח אחד לא חושפת תעבורה עבר.

8.6 הגדרת Site-to-Site IPsec VPN (ב-5 CLI שלבים)

```
===== שלב "ACL 0: מעניין" - איזו תעבורה להצפין =====
R1(config)# access-list 100 permit ip 10.1.1.0 0.0.0.255 10.2.2.0 0.0.0.255

===== שלב 1: מדיניות (ISAKMP) =====
R1(config)# crypto isakmp policy 10
R1(config-isakmp)# encryption aes 256
R1(config-isakmp)# hash sha
R1(config-isakmp)# authentication pre-share
R1(config-isakmp)# group 14 DH group 14 (2048-bit) !
R1(config-isakmp)# lifetime 3600
R1(config-isakmp)# exit
! מפתח משותף מראש + כתובת השכן
R1(config)# crypto isakmp key S3cr3tPSK address 200.2.2.2

===== שלב 2: transform set - הגנת Phase 2 =====
R1(config)# crypto ipsec transform-set TSET esp-aes 256 esp-sha-hmac
R1(cfg-crypto-trans)# mode tunnel
R1(cfg-crypto-trans)# exit

===== שלב 3: crypto map - מקשר הכול =====
R1(config)# crypto map CMAP 10 ipsec-isakmp
R1(config-crypto-map)# set peer 200.2.2.2
R1(config-crypto-map)# set transform-set TSET
R1(config-crypto-map)# match address 100 ! ה-ACL המעניין
R1(config-crypto-map)# set pfs group14
R1(config-crypto-map)# exit

===== שלב 4: החלה על הממשק החיצוני =====
R1(config)# interface g0/0
```

```
R1(config-if)# crypto map CMAP
```

PSK) (R2 ! מוגדר במראה: כתובות ו-ACL הפוכים, אותה מדיניות ואותו

טעויות נפוצות ב-IPsec

- מדיניות Phase 1 לא תואמת בין הצדדים (encryption/hash/group/auth שונים) ⇒ המנהרה לא קמה.
- **שני הצדדים חייבים להסכים.**
- PSK שונה משני הצדדים.
- ה-"ACL המעניין" לא מראה (R1: 10.1 → R2: 10.2; R2: 10.2 → R1: 10.1) אם לא הפוך – תעבורה לא נכנסת למנהרה.
- שכחו crypto map על הממשק – הכול מוגדר אבל כלום לא קורה.
- יש NAT שמתרגם את התעבורה המעניינת לפני ההצפנה ⇒ ה-ACL לא תואם. פתרון: NAT exemption (ACL עם deny לתעבורת ה-VPN).
- המנהרה קמה רק כשיש "תעבורה מעניינת" – ping אחד לא מספיק לפעמים; שלחו כמה.

ורפיקציה ופתרון תקלות

```
R1# show crypto isakmp sa      ! Phase 1 - מצב QM_IDLE = הצליח
R1# show crypto ipsec sa      ! Phase 2 - ספירת חבילות encrypted/decrypted
R1# show crypto map
R1# show crypto session
R1# debug crypto isakmp
R1# debug crypto ipsec
```

שאלת תלמיד: "איך אני יודע שהמנהרה עובדת ולא סתם ה-ping עובר רגיל?"

ב-`show crypto ipsec sa` תראו את המונים `#pkts encrypt` ו-`#pkts decrypt` עולים כשאתם שולחים תעבורה בין הרשתות. אם הם עולים – התעבורה עוברת במנהרה מוצפנת. אם ה-ping עובר אבל המונים 0 – התעבורה עוברת מחוץ למנהרה (בעיה ב-ACL המעניין או ב-NAT). זה הכלי הכי חשוב לדיבוג.

8.7 SSL/TLS VPN

	IPsec VPN	SSL VPN
שכבה	3 (רשת)	4-7 (מעל TCP 443)
לקוח	צריך תוכנת לקוח מותקנת ומוגדרת	Clientless – רק דפדפן (או לקוח קל AnyConnect)
מעבר חומות אש/NAT	לעיתים חסום (פרוטוקולים 50/51, UDP 500)	עובר בקלות – זה "רק" HTTPS על 443
גישה	גישת רשת מלאה	אפליקציות web ספציפיות (portal) או מלא (tunnel)
מתאים ל	site-to-site, גישה קבועה	גישה מרחוק ממחשב לא מנוהל, ספקים, ניידים

SSL VPN משתמש באותו TLS מפרק 7 (תעודות, AES, DH) זו הסיבה שהוא "פשוט עובד" מכל מקום – חומות אש כמעט תמיד מאפשרות 443.

8.8 ציוד וארכיטקטורה

- Cisco ASA 5500 – מכשיר האבטחה המרכזי: חומת אש (IPsec + VPN) ו-IPS. SSL יורשו: Firepower.
- Cisco PIX 500 – חומת האש/VPN ההיסטורית (הוחלפה ב-ASA); מוזכרת בתכנית.
- Cisco VPN 3000 Concentrator – ריכוז VPN מרחוק (הופסק); מוזכר בתכנית.
- SOHO – נתב קטן עם VPN מובנה לעסק/בית.

- האצת חומרה (בתכנית): VAC+, SPA, AIM – מודולי הצפנה שמורידים עומס מה-CPU היום מובנה במעבד.
- Cisco AnyConnect – לקוח ה-VPN המודרני (IPsec/SSL) למחשב ולנייד.

8.9 מדרוך פקודות מרוכז – פרק 8

שלב	פקודה
GRE	tunnel + interface tunnel 0 source/destination
IKE Phase 1	crypto isakmp policy N (encryption/hash/authentication/group)
PSK	crypto isakmp key K address PEER
הגנת Phase 2	crypto ipsec transform-set NAME esp-aes esp-sha-hmac
תעבורה מעניינת	access-list 100 permit ip SRC DST
קישור	(set crypto map NAME N ipsec-isakmp peer / transform-set / match address)
החלה	crypto map NAME (על ממשק)
ורפיקציה Phase 1	show crypto isakmp sa
ורפיקציה Phase 2 (מונים)	show crypto ipsec sa

8.10 תרגילים לתלמידים

תרגיל 1 – מתאים לאיזה VPN?

לכל תרחיש: Site-to-Site או Remote Access; ו-IPsec או SSL.

א. חיבור קבוע בין 3 סניפים. ב. עובד שמתחבר מבית קפה מהלפטופ. ג. ספק חיצוני שצריך לגשת לאפליקציית web אחת ממחשב לא מנוהל. ד. שרתי שני מוקדי נתונים שצריכים להעביר גיבויים.

א. Site-to-Site / IPsec. ב. Remote Access / IPsec. ג. Remote Access / SSL (AnyConnect). ד. SSL clientless Site-to-Site / IPsec.

תרגיל 2 – AH או ESP?

א. צריך גם הצפנה. ב. הצדדים מאחורי NAT. ג. רוצים רק לוודא שהחבילה לא שונתה בלי להצפין. מה נבחר בכל מקרה, ולמה בפועל תמיד ESP?

א. ESP (רק הוא מצפין). ב. AH (ESP נשבר עם NAT). ג. תיאורטית AH, אבל בפועל ESP במצב authentication-only תמיד ESP כי AH לא מצפין ולא עובד עם NAT.

תרגיל 3 – זהו את התקלה

המנהל הגדיר IPsec, show crypto isakmp sa מראה QM_IDLE, אבל ping בין הרשתות נכשל ו-0 encrypted. show crypto ipsec sa מראה מה כנראה הבעיה?

Phase 1 הצליח (יש ISAKMP SA), אבל Phase 2 לא מעביר תעבורה: כנראה ה-ACL המעניין לא תואם/לא הפוך בין הצדדים, או ש-NAT מתרגם את התעבורה לפני ההצפנה. בודקים match address ו-NAT exemption.

תרגיל 4 – מיפוי לפרק 7

בקונפיג: authentication pre-share, group 14, hash sha, encryption aes 256. לכל אחד – איזו מטרת CIA/תפקיד הוא ממלא ואיזה מושג מפרק 7 הוא?

aes 256 → סודיות (סימטרי). sha → שלמות group 14 (HMAC). → החלפת מפתחות (Diffie-Hellman).

8.11 שאלות בסגנון בגרות

שאלה 1

איזה סוג תקשורת נועדה חבילת הפרוטוקולים IPsec לאבטח? SSH / TCP/IP / TELNET / UDP
TCP/IP (שכבה 3 - ולכן כל התעבורה מעליו).

שאלה 2

מהו ההבדל בין AH ל-ESP, ומדוע בפועל משתמשים ב-ESP?
AH - שלמות ואימות בלבד, ללא הצפנה. ESP - שלמות, אימות והצפנה. משתמשים ב-ESP כי רק הוא נותן סודיות, וגם עובד עם NAT.

שאלה 3

מה תפקיד Phase 1 IKE לעומת Phase 2?
Phase 1 - בונה ערוץ ניהול מאובטח (ISAKMP SA): DH, אימות הצדדים, הסכמה על מדיניות. Phase 2 - בונה בתוכו את מנהרות הנתונים (IPsec SA) שדרךן עוברת התעבורה.

שאלה 4

מדוע GRE לבדו אינו מספיק לחיבור מאובטח בין סניפים, וכיצד פותרים?
GRE עוטף אך אינו מצפין - התעבורה גלויה. פתרון: GRE over IPsec (GRE לגמישות - multicast/routing), IPsec (להצפנה).

שאלה 5

מתי נעדיף SSL VPN על פני IPsec VPN?
גישה מרחוק ממחשב לא מנוהל / דרך דפדפן בלבד (clientless), וכשצריך לעבור חומות אש/NAT בקלות - SSL על 443 עובר כמעט תמיד.

שאלה 6

השלימו את הפקודה שמגדירה transform set עם AES ו-SHA: crypto ipsec transform-set _____ TSET _____
esp-aes esp-sha-hmac

8.12 מעבדה (3 שעות) - IPsec Site-to-Site ב-Packet Tracer

- טופולוגיה: LAN1 (10.1.1.0/24) — R1 — "אינטרנט" (R-ISP) — R2 — LAN2 (10.2.2.0/24) ודאו ניתוב מקצה לקצה (ping) עובר לפני. VPN).
- ב-R1 ו-R2 הגדירו את 5 השלבים מ-8.6. (במראה). PSK זהה, מדיניות זהה, ACL הפוך.
- מ-PC ב-LAN1 עשו ping ל-PC ב-LAN2 - יופעל "interesting traffic".
- show crypto isakmp sa ⇒ show crypto ipsec sa QM_IDLE ⇒ מונים עולים.
- ב-Simulation mode לכדו חבילה על קו ה"אינטרנט" - ראו שהיא ESP ולא ניתן לקרוא את התוכן.
- GRE (אופציונלי): הקימו מנהרת GRE והריצו OSPF דרכה; ראו ש-multicast של OSPF עובר - מה שלא היה עובד ב-IPsec לבדו.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

שאלות נפוצות בפרק ה-VPN, עם תשובות מוכנות.

ש: "מה ההבדל בין ה-VPN שאנחנו לומדים ל-VPN מסחרי כמו NordVPN?"
ת: VPN מסחרי נועד להסתיר את הזהות/המיקום שלכם ולעקוף חסימות. VPN ינוגרא (מה שאנחנו לומדים) מחבר בבטחה עובד או סניף אל רשת החברה. אותה טכנולוגיית מנהרה מוצפנת, מטרות שונות.

ש: "אם GRE יוצר מנהרה, למה הוא לא מספיק לחיבור מאובטח?"
ת: כי GRE רק פטוע את החבילה – הוא לא מצפין כלום. כל מי שמאזין בדרך רואה את התוכן. לכן משלבים "GRE: GRE over IPsec" נותן גמישות (מעביר multicast/ניתוב), IPsec נותן את ההצפנה.

ש: "IPsec מצפין – אז מה זה AH ו-ESP?"
ת: שני "אופנים" של IPsec. AH נותן שלמות ואימות בלבד – הנפצה ילב. ESP נותן שלמות, אימות הנפצה סגור. בפועל תמיד משתמשים ב-ESP (רק הוא מצפין, וגם עובד עם NAT).

ש: "למה IKE עובד בשני שלבים? זה נשמע מסובך."
ת: Phase 1 בונה קודם חטבואמ לוהינ פורע אחד (מבצע Diffie-Hellman ומאמת את הצדדים). רק בתוך הערוץ המוגן הזה, Phase 2 בונה את מנהרות הנתונים בפועל. זה כמו קודם לבנות חדר סגור, ואז לנהל בו את המשא-ומתן.

ש: "איך אני יודע שהמנהרה באמת עובדת ולא שה-ping סתם עובר רגיל?"
ת: show crypto ipsec sa – מסתכלים על המונים encrypt/decrypt #pkts. אם הם עולים כששולחים תעבורה, היא באמת עוברת מוצפנת. אם ה-ping עובר אבל המונים 0 – התעבורה עוברת פוחמ למנהרה (בעיה ב-ACL המעניין או ב-NAT).

ש: "מתי עדיף SSL VPN על IPsec?"
ת: כשצריך גישה מרחוק ממחשב להונמ אל או דרך דפדפן בלבד (clientless), וכשרוצים מעבר קל דרך חומות אש – SSL רץ על פורט 443 שכמעט תמיד פתוח. IPsec מתאים יותר לחיבורים קבועים (סניף לסניף).

ש: "המנהרה קמה (QM_IDLE) אבל ה-ping נכשל. מה קורה?"
ת: Phase 1 הצליח (יש ISAKMP SA) אבל Phase 2 לא מעביר תעבורה. הסיבות הנפוצות: ה-"ACL המעניין" לא רופה בין שני הצדדים, או ש-NAT מתרגם את התעבורה לפני ההצפנה. בודקים match address ופטור NAT-מ.

ש: "כל מה שהגדרתי ב-IPsec נראה נכון אבל המנהרה לא קמה בכלל. מה לבדוק?"
ת: מדיניות Phase 1 חייבת להיות ההז בשני הצדדים (encryption/hash/DH group/authentication) וגם ה-PSK זהה. אי-התאמה של אחד מהם מונעת מהמנהרה לקום. בודקים עם show crypto isakmp sa וdebug crypto isakmp-1.

מילון מונחים – הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה.

מונח	הגדרה
VPN	רשת פרטית וירטואלית – מנהרה מוצפנת דרך רשת ציבורית.
Site-to-Site	VPN בין שני שערים (סניפים), שקוף למשתמשים.
Remote Access	VPN של משתמש יחיד (עובד מהבית) אל שער החברה.
GRE	פרוטוקול מנהור שעוטף חבילות (כולל multicast) – אך אינו מצפין.
IPsec	מסגרת פרוטוקולים לאבטחת תעבורה בשכבה 3 (TCP/IP).
AH	פרוטוקול IPsec: שלמות ואימות בלבד – ללא הצפנה.
ESP	פרוטוקול IPsec: שלמות, אימות והצפנה; הבחירה המקובלת.
Transport / Tunnel mode	IPsec בין מארחים (transport) או בין שערים עם עטיפה (tunnel).

מונח	הגדרה
IKE	פרוטוקול שמקים את מנהרת ה-IPsec (מבצע DH ואימות).
Phase 1 / Phase 2	IKE: בונה ערוץ ניהול מאובטח (1) ואז את מנהרות הנתונים. (2)
SA (Security Association)	הסכם חד-כיווני המגדיר איך לאבטח זרם תעבורה, עם מזהה SPI.
PSK (Pre-Shared Key)	מפתח משותף מראש לאימות הצדדים ב-IKE (חלופה לתעודות).
Transform set	צירוף אלגוריתמי ההגנה של Phase 2 (למשל esp-aes esp-sha-hmac).
Crypto map	אובייקט שמקשר peer, transform set ו-ACL 'מעניין', ומוחל על ממשק.
interesting traffic	התעבורה (מוגדרת ב-ACL שאמורה לעבור במנהרה המוצפנת).
SSL/TLS VPN	VPN מעל 443 TCP; לרוב clientless (דרך דפדפן); עובר חומות אש בקלות.
Cisco ASA	מכשיר אבטחה המשלב חומת אש, VPN ו-IPS.